بِسْمِ اللّٰهِ الرَّحْمٰنِ الرَّحِيْمِ

اَلْحَمْدُ لِلّٰهِ رَبِّ الْعَالَمِيْنَ

وَالصَّلٰوةُ وَالسَّلَامُ عَلٰى خَاتَمِ النَّبِيِّيْنَ

Network Footprinting and Scanning

Knowledge is Power: But if used effectively

Network Footprinting and Scanning: Used to identify a targets:

- Geo-location and Network topology
- Running OS and Services

Roadmap:

1. **Passive footprinting** (Open Source Intelligence OSINT e.g. DNS, WHOIS)
2. **Mapping network topology**: Traceroute/tracert with WHOIS for hops
3. **Host discovery**: Ping sweep over target network
4. **Port & service discovery:** Targeted port-scan (TCP/UDP).
5. **Service & OS detection**: Fingerprinting responses to crafted probes

What is Footprinting?

Footprinting is the first step of any attack on information systems in which an attacker **collects information about a target network** to identify various ways to intrude into the system

Types of Footprinting

- **Passive Footprinting**
  - Gathering information about the target **without direct interaction**
- **Active Footprinting**
  - Gathering information about the target **with direct interaction**

Information Obtained in Footprinting

- **Organization information**
  - Employee details, telephone numbers, location, background of the organization, web technologies, etc.
- **Network information**
  - Domain and sub-domains, network blocks, IP addresses of the reachable systems, Whois record, DNS, etc.
- **System information**
  - OS and location of web servers, users and passwords, etc.

Objectives of Footprinting

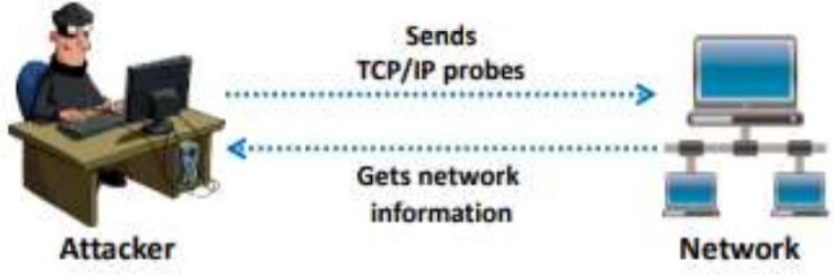
- Knowledge of security posture
- Reduction of focus area
- Identifying vulnerabilities
- Drawing of network map



Overview of Network Scanning

- Network scanning refers to a set of procedures used for **identifying hosts**, **ports**, and **services** in a network
- Network scanning is one of the **components of intelligence gathering** which can be used by an attacker to create a profile of the target organization

Network Scanning Process



Objectives of Network Scanning

- To discover live hosts, IP address, and open ports of live hosts
- To discover operating systems and system architecture
- To discover services running on hosts
- To discover vulnerabilities in live hosts



Footprinting Tools

nslookup: for quick, simple lookups

Dig: detailed, professional DNS queries

WHOIS: Internet protocol used to query databases that store registration information about domain names, IP address blocks, and autonomous systems. Runs over TCP port 43.

https://whatismyipaddress.com/

https://www.whois.com/whois/

https://www.whois.net

https://wq.apnic.net/static/search.html

https://whois.arin.net/ui/

https://dnschecker.org/all-tools.php



https://www.ipxo.com/blog/what-is-whois/

IP allocation

ICANN = Internet Corporation for Assigned Names and Numbers :

- A non-profit organization that oversees the global coordination of DNS and IP address allocation.

IANA = Internet Assigned Numbers Authority : incorporated into ICANN.

- Operated by ICANN, but its role is technical coordination, not policy-making.

IP assignment:

IANA: **Owner of IPs** that allocates IP blocks to RIRs

RIRs (Regional Internet Registry): regional IP authorities or **non profit IP wholesalers** that allocate subnets to ISPs, data centers, large enterprises. (E.G. APNIC, ARIN)

- ARIN – American Registry for Internet Numbers (North America)
- APNIC – Asia Pacific Network Information Centre (Asia-Pacific) i.e. relevant to **Pakistan**

ISP (Internet service provider): IP retailer that assigns static or dynamic IPs to subscribers

DNS Hierarchy

Root DNS servers: knows TLDs (13 logical roots, run by organizations under ICANN/IANA oversight)

Top Level Domain TLD: stores IPs of authoritative DNS for each record: (e.g .com, .org, .net, .pk, .edu, etc.) managed by its own Registry

Authoritative DNS (hosting DNS): Registered DNS servers that handle the target domain.

Non-authoritative DNS (local DNS): cached copies of DNS records locally or with a local ISP

<u>Domain Registration:</u>

Registry: the operator of a TLD server. Manages a TLD database

Registrar: seller of domains:

- ICANN-accredited companies (e.g GoDaddy, Namecheap, Google Domains) to sell/register domains.
    - **Sells a a human-readable domain**
    - **Updates the central registry with domain info and name servers.**

Traceroute

```
traceroute to 8.8.8.8 (8.8.8.8), 64 hops max
 1  router.lan (172.16.16.1)  2.884 ms  1.44
 2  103.4.94.105.pern.pk (103.4.94.105)  2.3
 3  172.31.70.53 (172.31.70.53)  3.371 ms  5
 4  static.lhr63.pie.net.pk (221.120.208.5)
```

Command: **“Traceroute”** on linux “**tracert”** on windows

Windows tracert sends **ICMP Echo Request** packets (like ping)

Linux traceroute sends **UDP datagrams** to high-numbered ports (33434+).

Reveals the path to a destination on internet

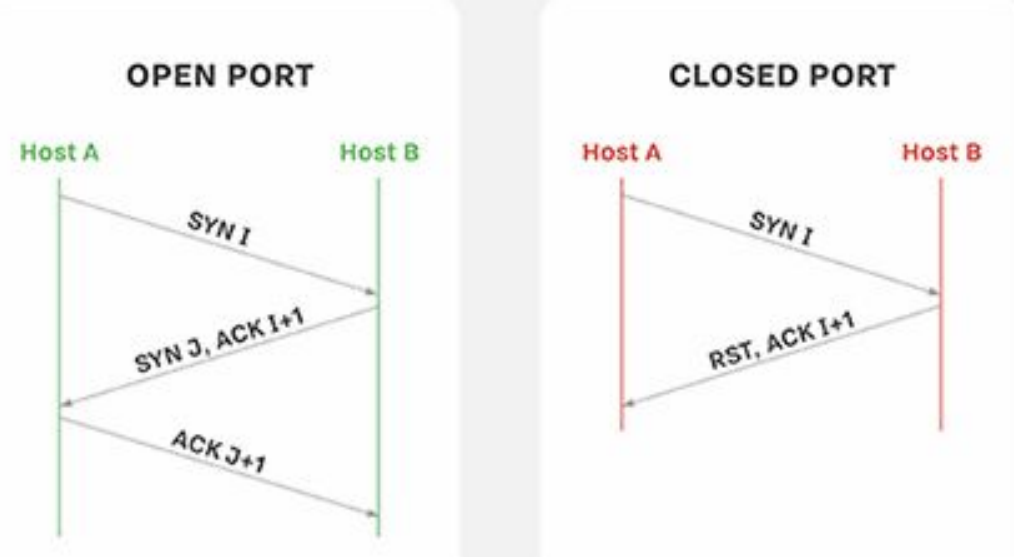
- Sends packets with increasing **TTL** (time-to-live) values starting from 1
- Hop routers return ICMP “**Time Exceeded**” messages when the TTL expires.
- The final hop responds differently (**usually an ICMP Echo Reply or an ICMP Port Unreachable**), so you know you reached the destination.

Fingerprinting intermediate Hop IPs (e.g. by WHOIS can help understand topology)

Firewalls or filtering can hide hops or cause open/filtered-like behavior in traceroute.

Network and Port Scans

Network scan (Ping sweep): tries to ping (icmp echo) on a subnet and flags the responding hosts as live



https://www.techtarget.com/searchsecurity/answer/What-is-a-port-scan-attack

TCP scans

Attacker sends: SYN

If Target responds with:

- **SYN/ACK → port open**
- **RST → port closed**
- **No reply → port is filtered by a firewall**

Attacker then either sends: ACK (for connect scan) or nothing (for syn scan)

UDP scan

```
└─$ sudo nmap -sU 192.168.0.1 -p 631-635
Starting Nmap 7.91 ( https://nmap.org ) at 2021-09-21 09:24 EDT
Nmap scan report for 192.168.0.1
Host is up (0.00066s latency).

PORT    STATE         SERVICE
631/udp open|filtered ipp
632/udp closed        bmpp
633/udp closed        servstat
634/udp closed        ginad
635/udp closed        mount
MAC Address: 08:00:27:4B:32:42 (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 14.50 seconds
```

UDP has no built-in handshake.

A probe is just a datagram sent to a port;

- **Closed port** usually replies with an **ICMP Port Unreachable**
- **Open UDP service** typically **doesn't reply to an ordinary empty packet.**
- Firewalls or filtering can also drop probes or ICMP errors causing ambiguity.

Nmap therefore flags a port open/filtered in case of no reply

Or alternatively uses a combination of probes, retries, and protocol-specific payloads to interpret replies

Service and OS scan

Service scan

Nmap detects **active service/version/implementation** by sending **protocol-aware** probes to an open port, and collecting the response

```
PORT    STATE SERVICE VERSION
22/tcp  open  ssh     OpenSSH 6.7p1
25/tcp  open  smtp    Postfix smtpd
80/tcp  open  http    nginx 1.6.2
110/tcp open  pop3    Dovecot pop3d
```

OS scan

Nmap actively fingerprints a target's TCP/IP stack by sending a series of crafted probes (various TCP, UDP and ICMP packets) and **comparing the target's responses (flags, TTL, window size, options) against a database** of known fingerprints to guess which OS and version (or family) is running.

E.g**:** Default ICMP Echo Reply by **Windows** usually has **TTL = 128**. While that by **Linux** has **TTL = 64**.

NMAP (open source tool, pre-installed in Kali)

Help: Nmap -h

ping sweep: nmap -sn (subnet) e.g: **nmap -sn 192.168.1.0/24**

Udp scap: nmap -sU (host)-p (ports) e.g: **nmap -sU -p 53,67-69 192.168.1.10**

Tcp connect scan: -sT e.g: **nmap -sT -p 22,80,443 192.168.1.10**

Tcp syn scan: -sS e.g: **nmap -sS -p 1-1000 192.168.1.10**

Service /version scan: -sV e.g.: **sudo nmap -sV -p 22,80 192.168.1.10**

Os scan: nmap -O (host) e.g: **nmap -O 192.168.1.10**

Advanced options: aggressive scan, verbose level, output format

Port ranges : Well-known (0-1023): Registered (1024-49151), Private (49152-65535)

Activity

Perform footprinting for our university website and map its network topology,

Then ping sweep for its whole subnet,

Perform TCP/UDP scans and OS detection for a particular IP

Use nmap on local kali vm (besides trying online tools)

Additional: complete the following free tryhackme rooms

https://tryhackme.com/room/nmap01

https://tryhackme.com/room/furthernmap